КРАТКИЙ ИТОГ НА ОДНОЙ СТРАНИЦЕ

Постквантовая проверка криптографии: bitbox02-firmware-en @ ae548ef4e40f

Клиент: BitBox (Shift Crypto) — публичный репозиторий (пассивная проверка) · Код: github.com/BitBoxSwiss/bitbox02-firmware, коммит `ae548ef4e40f` · Проверено: 2026-11-04 20:10 UTC · Профиль риска: Криптобиржа, кастодиан или кошелёк

ПОСТКВАНТОВАЯ ЗРЕЛОСТЬ

Уровень 0 из 4

постквантовой криптографии нет

НАХОДКИ

1 Критическая **11** Высокая
58 Средняя **3** Низкая
6 Информационная

КВАНТОВЫЙ СРОК (МОСКА: X + Y − Z)

Обмен ключами: 10 + 5 − 8 = 7 → **слишком поздно**
Подписи: 10 + 5 − 8 = 7 → **слишком поздно**

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

ГЛАВНОЕ

Критическая QSI-2026-13280	**certifi 2022.12.7 затронут GHSA-6q48-6c7w-9gw2 (PYSEC-2026-4320)** Что сделать: Обновите до исправленной версии (2026.10.18).
Высокая QSI-2026-13256	**Проверка TLS-сертификата отключена в scripts/generate_version_headers.py** Что сделать: Удалите отключение; используйте корректный набор УЦ или пиннинг.
Высокая QSI-2026-13281	**certifi 2022.12.7 затронут GHSA-xqr8-7jwr-rhp7 (CVE-2023-37920, PYSEC-2023-135)** Что сделать: Обновите до исправленной версии (2023.7.22).
Высокая QSI-2026-13285	**jinja2 3.1.2 затронут GHSA-gmj6-6f8f-6699 (CVE-2024-56201, PYSEC-2026-1472)** Что сделать: Обновите до исправленной версии (3.1.5).

Ещё 69 — в полном отчёте.

ЧТО ЗАЩИЩАЕТ КВАНТОВО-УЯЗВИМАЯ КРИПТОГРАФИЯ

Роль	Алгоритмы	Что сделать
Средняя проверка прошивки и загрузки (корень доверия)	ECDSA	Запланируйте гибридную подпись прошивки (классическая плюс ML-DSA или SLH-DSA, обе обязательны) и способ...
Средняя обёртка ключей и шифрование хранимых данных	ECDH, X25519	Оборачивайте ключи ML-KEM или гибридным KEM (X25519 + ML-KEM-768) и переоберните хранимые ключи; для данных...
Средняя обмен ключами в канале (TLS, Noise, рукопожатия)	X25519	Переведите рукопожатие на гибридный обмен ключами (X25519MLKEM768 в TLS 1.3; гибридный KEM в протоколах на...
Средняя подпись транзакций и сообщений	ECDSA, Ed25519, Schnorr (BIP-340)	Следите за постквантовыми планами каждой сети, не используйте открытые ключи повторно и держите подписание...

ИЗВЕСТНЫЕ УЯЗВИМЫЕ ВЕРСИИ КОМПОНЕНТОВ

Бюллетеней для используемых версий: 32; применимость к этой сборке маловероятна: 4 (флаг Cargo выключен, затронутые функции в коде не упоминаются или платформа не собирается); требуют разбора: 28.

Проверка аналитика: подтверждено — 15, не применимо — 5, отклонено как ложные срабатывания — 0. (QSI review, 2026-10-28)

Статический анализ исходного кода и манифестов; проанализировано файлов: 2645. Запросы к системам владельца не отправлялись.

Полный отчёт, SHA-256 содержимого: `97427c688295170a9412989d617c735b3fae306bc47fc10b3b62313b102f1115`

Подпись полного отчёта (report.sig.json): ключ Ed25519, отпечаток SHA-256 `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json содержит SHA-256 каждого файла комплекта и тоже подписан; verify-bundle проверяет его без сети.

Предварительные находки требуют подтверждения в коде; доказательства, границы каждой проверки и порядок повторной проверки — в полном отчёте.